

1. Refined Requirement Baseline

Functional Requirements

- FR-1 — Create text note. The system shall let a user create a Note with a non-empty title (1–200 characters) and a body of UTF-8 markdown (≤ 1 MB). On successful creation the system shall persist `created_at` and `updated_at` (ISO 8601 UTC) and return a stable id (UUID v4).
- FR-2 — Edit note. The system shall let a user modify the title or body of an existing Note. The modification shall be atomic: either the new state is fully persisted with an updated `updated_at` and a new VersionHistory entry, or the original state is preserved unchanged.
- FR-3 — Delete note. The system shall let a user delete a Note. The deleted Note shall be moved to a recoverable trash for at least 7 days; permanent deletion after that interval shall be irreversible and shall write an audit-log entry.
- FR-4 — Mark note as private. The system shall let a user designate any Note as a SecureNote with a passphrase of at least 12 characters. After designation the body shall be re-encoded as `encrypted_body`: bytes and the plaintext shall not be retained on disk, in memory dumps, or in logs.
- FR-5 — Persist and reload locally. The system shall persist all Notes to local storage and shall reload the user's collection on next start with no data loss in the absence of disk corruption.
- FR-6 — Version history. The system shall record an append-only VersionHistory entry on every save, capturing `note_id`, `version`, `changed_at`, `body_diff`, and `encrypted_body`. The user shall be able to list and restore any prior version. Restoring a version shall append a new VersionHistory entry rather than overwriting earlier entries.
- FR-7 — Cloud Sync. The system shall let a user opt in to a sync service that mirrors Notes across the user's authenticated devices. SecureNotes shall remain end-to-end encrypted in transit and at rest on the server. On detected conflict the system shall prompt the user rather than silently choosing a winner.
- FR-8 — Search notes. The system shall let a user search Notes by title and body text and shall return a ranked list ordered by recency. Body content of locked SecureNotes shall not contribute to search results until the user unlocks them.

Non-Functional Requirements

- NFR-1 — Responsiveness with 10k notes. With a collection of 10,000 Notes on commodity hardware (8 GB RAM, SSD), opening the application shall complete in under 1.5 seconds p95, and a search query shall return ranked results in under 100 ms p95.
- NFR-2 — MVC separation. The system shall follow the MVC pattern from the Project Charter. The View shall not import any module from `astranotes.repository` or `astranotes.services.encryption`; the Model shall not import any view-layer module. Violations shall be detected by an automated import-graph check in CI.

Security, Privacy, and Governance Requirements

- SEC-1 — Encryption at rest for SecureNotes. SecureNote bodies shall be encrypted using authenticated symmetric encryption. The encryption key shall be derived from the user's passphrase via a memory-hard KDF with per-note salt. Plaintext bodies shall not be persisted to disk or written to logs at any time.
- SEC-2 — Graceful failure. The system shall handle invalid save, load, delete, or sync operations without crashing. Every user-facing error shall include a short message explaining what failed and what the user can do; internal stack traces shall be written to a debug log only.
- SEC-3 — Dependency hygiene. Every external dependency shall be pinned to an exact version, justified in writing, and reviewed before use. The dependency set shall be minimized; the Phase 1 baseline is cryptography only. New dependencies require a written justification linked to a requirement ID.
- SEC-4 — Audit log. The system shall maintain an append-only local audit log of create, edit, delete, restore, sync, and security events. Each entry shall include event_type, note_id, timestamp, and source. The log shall not contain plaintext SecureNote bodies.

2. Ambiguity Review

Original phrase	Why it was ambiguous	Refined as
"the system should be fast"	"Fast" is unmeasurable. Fast at what? On what hardware? At what scale?	NFR-1: 100 ms p95 search and 1.5 s open at 10k notes on stated hardware.
"private notes are private"	"Private" could mean hidden from listing, password-prompted, or cryptographically protected. Each implies a different cost.	FR-4 + SEC-1: encrypted-at-rest with a memory-hard KDF; plaintext never persisted.
"delete a note"	Delete how? Soft? Hard? Recoverable?	FR-3: 7-day recoverable trash, then irreversible permanent delete with audit-log entry.
"save different types of notes"	Which types? How extensible?	FR-1 plus the PluginManager design — Text / Voice / Secure as plugin slots.
"sync across devices"	One-way? Two-way? Conflict policy? Server access to plaintext?	FR-7: two-way authenticated sync, conflict prompt rather than silent merge, end-to-end encryption for SecureNotes.

3. Edge-Case Review

For each refined requirement I identified at least one edge case that the design must handle.

Requirement	Edge case	Decision
FR-1	Title is empty or > 200 chars; body > 1 MB	Reject with SEC-2 user-facing error.
FR-2	Save crashes mid-write	Use atomic writing so the original Note survives.
FR-3	User restores from trash after 7 days	Permanent delete is irreversible by design; users are warned at trash-purge time.
FR-4	User forgets the passphrase	No backdoor. SEC-1 forbids storing the plaintext key; the SecureNote body is unrecoverable. This is documented as an explicit user-visible warning, not a TODO.
FR-5	Local store file is corrupted	Application starts in read-only recovery mode and prompts the user, instead of crashing.
FR-6	A version's diff is corrupted	Restore from the previous good version; corrupt entry is flagged in the audit log.
FR-7	Conflict on the same note edited offline on two devices	User is prompted to choose. Both versions are preserved as VersionHistory entries.
FR-7	Sync server is unreachable	Application continues local-first; sync resumes automatically when reachable.
FR-8	Query matches only inside a locked SecureNote	Search returns only the title and a "locked" indicator; body matches are revealed only after unlock.
NFR-1	10k-note search exceeds 100 ms on the target hardware	Sprint-Zero spike S0-11 measures this; if exceeded, switch to SQLite FTS5 indexing or revisit NFR-1.
SEC-1	A future plugin tries to write plaintext SecureNote bodies	Encryption boundary is enforced by the EncryptionService; the View and plugins cannot reach it directly per NFR-2.
SEC-3	A new transitive dependency is introduced by cryptography upgrade	Lockfile review on every dependency bump; CI fails if a new package is unjustified.

SEC-4	Audit log fills the disk	Log is rotated daily and capped (e.g., 100 MB) with the oldest entries archived.
-------	--------------------------	--
